



ELISA

Enabling **Linux** in
Safety Applications

ELISA Workshop London, UK

June 9-11, 2026
Co-hosted with Canonical





ELISA

Enabling **Linux** in
Safety Applications

Comparing ELISA Lighthouse OSS SIG checklist with Existing OSS Best-Practice Frameworks

Wendi Urribarri (Woven by Toyota)

Philipp Ahmann (ETAS GmbH)

ELISA Workshop: London, UK

June 11, 2026

Co-hosted with Canonical

**PLEASE "BEAR"
WITH ME**



I HAVE A VOICE DISORDER

It affects the sound of my voice and can make it difficult to speak.
I am not sick or nervous. Your patience is appreciated.



DYSPHONIA INTERNATIONAL

LEARN MORE AT
[DYSPHONIA.ORG](https://dysphonia.org)

Let's clarify together how existing frameworks
can support open source quality assessment,
and where the Lighthouse checklist can
complement them



A practical OSS quality assessment checklist

Why it is needed

No single standardized way to assess OSS quality today

Projects vary in

- Governance
- Development practices
- QA
- Security and supply-chain management
- Documentation
- Sustainability models



Lighthouse OSS SIG Checklist

OSS best practices for assessment



Who it supports

Broadly applicable to:

- OSS maintainers
- OSS adopters
- OEMs
- Foundations
- Researchers
- Quality/Safety/Security engineers
- Compliance teams
- Anyone seeking OSS improvement paths

Assessment lens

Process
Robustness



Evidence
Confidence

Longer-term ambition

Build a common basis for OSS quality assessment, complementing existing frameworks, and potentially supporting a future standardization path

Landscape: many useful programs, different jobs

What job does each program do?

- 1 Checklists** What should a project or organization do?
- 2 Automated evaluators** What signals can we collect from repositories?
- 3 Metrics / Analytics frameworks** What trends show community health or sustainability?
- 4 Organization / process conformance** What management-system or compliance process exists?
- 5 Trust / risk methodologies** What evidence supports trust for a software release?
- 6 Bodies of knowledge / guidance** What broader discipline knowledge can inform practices?

Programs considered: [link](#)

Lighthouse OSS Checklist

- Priority 1** OpenSSF Badge · Eclipse TSF · Apache PMM 
-
- Priority 2** OpenSSF Scorecard · OSPS Baseline · CHAOSS · LFX Insights
-
- Priority 3** OpenChain · CNCF TAG Security Self-Assessment
-
- Priority 4** NIST SSDF · SEBoK · SWEBOK · ISO 42003 · LF Responsible AI · ISO/IEC 5055
-
- Priority 5** Joint Development Foundation · TODO Group Guides

Comparison question: *What decision does this program help us make?*

The comparison is less about ranking programs, and more about understanding their role

- Primary signal
- ◐ Secondary or partial signal
- Indirect or contextual signal
- Not central

Three programs examined more in detail

OpenSSF Best Practices Badge

Actionable criteria

Practical project-level checklist with clear criteria, evidence fields, and badge levels

Eclipse Trustable Software Framework

Structured evidence model

Way to organize release-level evidence and reason about trust, risk, and reproducibility

Apache Project Maturity Model

Community maturity

Concise model for evaluating community and codebase maturity: merit, consensus, public communication, releases

Area	OpenSSF Best Practices Badge	Eclipse TSF	Apache PMM	Lighthouse OSS Checklist
Governance & roles	◐	—	●	●
Development practices	●	◐	◐	●
QA / testing	●	◐	◐	●
Security & vulnerability handling	●	◐	◐	●
Supply-chain / provenance	◐	●	○	◐
Evidence & traceability	◐	●	○	●
Community health & sustainability	○	—	●	●

Discussion

Where should the Lighthouse checklist add value?

ELISA Lighthouse OSS Checklist

Broad, practice-centered assessment layer linking practices to evidence

1 Is the practice defined and embedded?

2 Is there observable evidence?

Complementarity

Which frameworks should we reference rather than re-create?

Output

Should the SIG produce other than a checklist? A mapping guide, a maturity model, an assessment playbook...?

Quality

What practices are directly related to quality? Which are supporting quality? Which are best practices, but not necessarily required for safety? E.g., how does "license type" or "bus factor" impact OSS quality/safety/security?

Evidence

What evidence should count for each Lighthouse practice? Public documents, issues, commits, CI logs, release artifacts, third-party checks?

Audience topics

What else should the SIG consider?

Thank you!

